

Executive Cyber Risk Summary

Northstar Health Technologies

Enterprise Cyber Risk Assessment
Cyber Risk Management / GRC

Assessment Status: Completed Portfolio Demonstration
Assessment Date: September 2026
Framework References: ISO/IEC 27001 · NIST CSF · NIST SP 800-30

1. Executive Overview

Northstar Health Technologies conducted an enterprise cybersecurity risk assessment covering critical information assets, cloud infrastructure, applications, identity systems, endpoints, security operations, business processes, and third-party dependencies.

The assessment identified **15 cybersecurity risks across 20 organizational assets**.

The assessment uses a 5x5 likelihood and impact model, producing risk scores from 1–25.

Overall Risk Posture

Metric	Result
Assets Assessed	20
Risks Identified	15
Critical Inherent Risks	6
High Inherent Risks	9
Moderate/Low Inherent Risks	0
High Residual Risks	10
Moderate Residual Risks	5
Critical Residual Risks	0
Treatment Strategy	Mitigate

The assessment indicates that Northstar's most significant cybersecurity exposure is concentrated around **sensitive information, identity and access management, internet-facing applications, cloud configuration, credentials, and operational resilience**.

Following the proposed treatment activities, no risks remain at the Critical residual-risk level. However, several High residual risks require continued management attention and ongoing monitoring.

2. Risk Profile

Inherent Risk

Before additional treatment, the assessment identified:

- **6 Critical risks**
- **9 High risks**
- **0 Moderate risks**
- **0 Low risks**

This indicates that the organization's most important exposures are concentrated in assets and processes supporting critical business operations and sensitive information.

Residual Risk

After the proposed treatment measures are considered:

- **0 Critical**
- **10 High**
- **5 Moderate**
- **0 Low**

The reduction in risk level demonstrates the expected effectiveness of the proposed security controls while recognizing that some cybersecurity exposure remains.

3. Highest-Priority Risks

The following risks represent the most significant areas requiring management attention:

Risk ID	Risk	Inherent	Residual	Owner
R-001	Unauthorized Access to Customer & Patient Data	20 Critical	10 High	CISO
R-003	Customer Web Application Compromise	20 Critical	10 High	VP Engineering
R-004	API Security / Unauthorized Access	20 Critical	10 High	VP Engineering

Risk ID	Risk	Inherent	Residual	Owner
R-005	Cloud Misconfiguration	20 Critical	10 High	CTO
R-006	Account Compromise / Excessive Privileges	20 Critical	10 High	CISO
R-012	Credential / Secret Exposure	20 Critical	10 High	CISO

These risks involve systems or information that could materially affect confidentiality, integrity, availability, regulatory obligations, and business operations.

4. Key Risk Themes

Identity and Access Management

Several risks involve unauthorized access, excessive privileges, credential compromise, and inappropriate access to sensitive information.

Management priority: Maintain strong MFA, least-privilege access, privileged-access reviews, account lifecycle controls, and authentication monitoring.

Application and API Security

The customer-facing application and API layer represent significant attack surfaces.

Management priority: Maintain secure SDLC practices, recurring application/API security testing, vulnerability remediation, secure code review, and application monitoring.

Cloud Security

Cloud configuration weaknesses could expose critical production infrastructure or data.

Management priority: Maintain configuration baselines, continuous configuration monitoring, IAM reviews, network-security reviews, and remediation of high-risk findings.

Operational Resilience

Backup and recovery capabilities are critical to maintaining availability following a security incident or operational disruption.

Management priority: Validate backup coverage, protect backups from unauthorized modification or deletion, and conduct periodic restoration testing.

Third-Party Risk

Cloud and SaaS dependencies introduce additional security and operational exposure.

Management priority: Maintain vendor classification, security due diligence, contractual security requirements, periodic reassessment, and remediation tracking.

5. Treatment Status

The risk treatment plan uses four possible treatment strategies:

- **Mitigate**
- **Transfer**
- **Avoid**
- **Accept**

For this assessment, all identified risks have been assigned **Mitigate** as the primary treatment strategy because the underlying business activities remain necessary to Northstar's operations.

Treatment status varies according to the fictional assessment scenario:

- **Planned** — treatment has been identified but implementation has not begun.
 - **In Progress** — remediation activities are underway.
 - **Implemented** — identified controls have been implemented.
 - **Validated** — implemented controls have been tested and their effectiveness evidenced.
-

6. Management Priorities

Management should prioritize the following activities:

1. Strengthen Identity and Access Controls

Continue MFA enforcement, privileged-access management, periodic access reviews, and removal of unnecessary permissions.

2. Improve Application and API Security

Maintain recurring security testing and ensure critical vulnerabilities are remediated within defined timelines.

3. Strengthen Cloud Configuration Management

Implement continuous monitoring and establish approved configuration baselines for production environments.

4. Improve Detection and Monitoring

Expand security-log coverage, improve detection use cases, tune alerting, and periodically test detection capabilities.

5. Validate Business Continuity and Recovery

Conduct periodic backup restoration tests and validate recovery procedures against defined RTO/RPO requirements.

6. Maintain Third-Party Risk Oversight

Continue vendor classification, security assessments, contractual security requirements, reassessments, and remediation tracking.

7. Residual Risk Management

Residual risk should be treated as an ongoing management responsibility rather than a one-time assessment outcome.

Risk owners should:

- Monitor identified risks against established thresholds.
- Review treatment progress.
- Validate control effectiveness.
- Track changes in threat exposure.
- Reassess risks when significant environmental or business changes occur.
- Escalate risks exceeding organizational tolerance.
- Document formal risk acceptance decisions when appropriate.

High residual risks should remain visible to management until their likelihood or impact is reduced to an acceptable level.

8. Recommended Monitoring

Key indicators should include:

- Critical and high-severity vulnerabilities overdue for remediation

- Privileged-access review completion
- MFA coverage
- Security monitoring/log-source coverage
- High-severity security alerts
- Backup success and restoration-test results
- Third-party assessment completion
- Open security incidents
- Critical cloud configuration findings
- Customer-data access anomalies

These indicators can be incorporated into periodic **KRI/KPI dashboards and management reviews**.

9. Conclusion

The assessment demonstrates a structured approach to identifying, evaluating, treating, and monitoring cybersecurity risk across a cloud-based healthcare technology environment.

The most significant inherent risks involve sensitive data, application security, cloud infrastructure, identity and access management, credentials, and operational resilience.

The proposed treatment activities reduce the assessed risk exposure, eliminating Critical residual-risk ratings in the modeled scenario. However, **10 High residual risks remain**, demonstrating that cybersecurity risk cannot be eliminated entirely and requires continuous monitoring, control improvement, and management oversight.

Northstar should continue to treat cybersecurity risk as an ongoing business-management activity integrated with security operations, technology management, vendor governance, business continuity, and executive decision-making.

Portfolio Disclaimer

This assessment is a fictional or synthetically recreated demonstration inspired by and based on real-world professional cybersecurity, GRC, risk management, compliance, and security assessment projects.

The organization, systems, assets, scenarios, findings, risk ratings, and other project-specific details have been created or modified for portfolio and educational purposes.

No confidential, proprietary, client, or employer information is included in this project.